

METASPLOITABLE 2 VULNERABILITY ASSESSMENT REPORT

Network Vulnerability Assessment Using Nessus Essentials

Prepared by: Iwuji Daniel

Organization: TechSecure Systems

Assessment Platform: Kali Linux/VirtualBox

Target System: Metasploitable 2

Vulnerability Scanner: Nessus Essentials

EXECUTIVE SUMMARY

The vulnerability assessment of the TechSecure Systems laboratory environment was conducted to identify security weaknesses affecting a deliberately vulnerable Metasploitable 2 system. The assessment was performed using Kali Linux, with Nessus Essentials used as the primary vulnerability-scanning platform.

The Nessus scan of the target system, 10.0.2.3, completed successfully and identified 73 vulnerabilities across different severity levels. Seven significant findings were selected for detailed assessment based on their severity and potential security impact. These included UnrealIRCd Backdoor Detection, VNC Server 'password' Password, Bind Shell Backdoor Detection, SSL Version 2 and 3 Protocol Detection, rsh Service Detection, Samba Badlock Vulnerability, and Unencrypted Telnet Server.

The findings demonstrate several weaknesses, including backdoor-enabled services, weak authentication, insecure remote-access protocols, outdated cryptographic protocols, and vulnerable network services. These weaknesses could potentially allow unauthorized access, remote command execution, credential exposure, or compromise of the target system.

Recommended technical controls and security policies were developed to address the identified weaknesses. Key recommendations include removing vulnerable or unnecessary services, applying security patches, replacing insecure protocols with secure alternatives, enforcing strong authentication, restricting network exposure, and implementing continuous vulnerability management.

METHODOLOGY

The assessment followed a structured vulnerability-assessment process designed to identify exposed services, detect vulnerabilities, evaluate their potential impact, and develop appropriate security controls.

1. Laboratory Environment

The assessment was conducted in an isolated virtual laboratory using:

- Kali Linux — security testing and vulnerability-assessment workstation.
- Metasploitable 2 — intentionally vulnerable target system.
- VirtualBox — virtualization platform used to host the laboratory machines.
- Nessus Essentials — vulnerability-scanning and assessment platform.
- Nmap — network discovery and service-enumeration tool.

The Metasploitable 2 target was identified at:

IP Address: 10.0.2.3

2. Network and Service Discovery

Nmap was used to identify accessible network services and open ports on the target system. This provided an initial understanding of the target's attack surface and helped identify services requiring further security assessment.

The assessment included service and version enumeration and vulnerability-oriented Nmap scanning where appropriate.

3. Vulnerability Scanning

After confirming that the target was reachable from Kali Linux, Nessus Essentials was configured to perform a Basic Network Scan against 10.0.2.3.

The scan was conducted using the local Nessus scanner. The completed assessment identified 73 vulnerabilities across multiple severity levels.

4. Vulnerability Analysis

The Nessus results were reviewed to identify significant findings based on their severity, affected services, and potential security impact.

Seven findings were selected for detailed documentation:

- UnrealIRCd Backdoor Detection

- VNC Server 'password' Password
- Bind Shell Backdoor Detection
- SSL Version 2 and 3 Protocol Detection
- rsh Service Detection
- Samba Badlock Vulnerability
- Unencrypted Telnet Server

For each selected vulnerability, the affected service, port, severity, potential attacker objective, and recommended security control were documented.

5. Evidence Collection

Screenshots of the Nessus scan summary and individual vulnerability findings were captured as supporting evidence. These provide visual confirmation of the assessment results and can be referenced within the final security assessment report.

6. Remediation Planning

Based on the identified vulnerabilities, appropriate technical controls and security policies were developed. These recommendations focus on patch management, secure authentication, removal of unnecessary services, network access restrictions, secure communication protocols, and continuous vulnerability monitoring.

VULNERABILITY FINDINGS

The Nessus vulnerability assessment of the Metasploitable 2 target identified 73 vulnerabilities across multiple severity levels. Seven significant findings were selected for detailed analysis based on their severity, affected services, and potential security impact.

NO.	Vulnerability	Service	Port	Severity	CVSS
VULN-01	UnrealIRCd Backdoor Detection	IRC	6667/TCP	Critical	10.0
VULN-02	VNC Server ' <i>password</i> ' Password	VNC	5900/TCP	Critical	10.0
VULN-03	Bind Shell Backdoor Detection	wild_shell	1524/TCP	Critical	9.8
VULN-04	SSL Version 2 & 3 Protocol Detection	PostgreSQL, SMTP	5432/TCP, 25/TCP	Critical	9.8
VULN-05	Rsh Service Detection	rsh	514/TCP	High	7.5
VULN-06	Samba Badlock Vulnerability	CIFS	445/TCP	Medium	7.5
VULN-07	Unencrypted Telnet Server	Telnet	23/TCP	Medium	6.5

3.1 UnrealIRCd Backdoor Detection

- Affected Service: IRC – 6667/TCP
- Severity: Critical
- CVSS Score: 10.0

Nessus identified a backdoor vulnerability in the UnrealIRCd service running on TCP port 6667. The affected version contains malicious code that can allow an unauthenticated remote attacker to execute commands on the target system. Successful exploitation could result in unauthorized access and compromise of the affected host.

Potential Impact: Remote command execution, unauthorized system access, system compromise, and possible use of the compromised host for further attacks.

The screenshot displays the Tenable Nessus Essentials web interface. The browser address bar shows the URL: `localhost:8834/#scans/reports/5/vulnerabilities/46882`. The page title is "Metasploitable2 Vulnerability Assessment / Plugin #46882". The main content area is titled "UnreallIRCd Backdoor Detection" and is marked as "CRITICAL".

Description: The remote IRC server is a version of UnreallIRCd with a backdoor that allows an attacker to execute arbitrary code on the affected host.

Solution: Re-download the software, verify it using the published MD5 / SHA1 checksums, and re-install it.

See Also:

- <https://seclists.org/fulldisclosure/2010/jun/277>
- <https://seclists.org/fulldisclosure/2010/jun/284>
- <http://www.unreallircd.com/text/unreallsecadvisory.20100612.txt>

Output:

```
The remote IRC server is running as :
uid=0 (root) gid=0 (root)

To see debug logs, please visit individual host
```

Port	Hosts
6667 / tcp / irc	10.0.2.3

Plugin Details:

- Severity: Critical
- ID: 46882
- Version: 1.16
- Type: remote
- Family: Backdoors
- Published: June 14, 2010
- Modified: April 11, 2022

Risk Information:

- Risk Factor: Critical
- CVSS v2.0 Base Score: 10.0
- CVSS v2.0 Temporal Score: 8.3
- CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C
- CVSS v2.0 Temporal Vector: CVSS2#E:F/RL:OF/RC:C

Vulnerability Information:

- CPE: cpe:/a:unreallircd:unreallircd
- Exploit Available: true
- Exploit Ease: Exploits are available

Nessus evidence for UnreallIRCd Backdoor Detection

3.2 VNC Server 'password' Password

- ❖ Affected Service: VNC – 5900/TCP
- ❖ Severity: Critical
- ❖ CVSS Score: 10.0

Nessus identified that the VNC service is configured with the weak password password. Because VNC provides remote graphical access, an attacker who can reach the service and successfully authenticate could potentially obtain unauthorized access to the system.

Potential Impact: Unauthorized remote desktop access, exposure of sensitive information, unauthorized actions, and potential compromise of the target system.

The screenshot displays the Nessus Essentials web interface in a browser window. The address bar shows the URL: localhost:8834/#/scans/reports/5/vulnerabilities/61708. The interface is in dark mode. On the left sidebar, there are sections for 'FOLDERS' (My Scans, All Scans, Trash) and 'RESOURCES' (Policies, Plugin Rules). The main content area is titled 'Metasploitable2 Vulnerability Assessment / Plugin #61708'. It features tabs for 'Hosts', 'Vulnerabilities' (selected), 'Remediations', and 'History'. The 'Vulnerabilities' tab shows a single entry: 'VNC Server 'password' Password' with a 'CRITICAL' severity. The entry is expanded, showing the following details:

- Description:** The VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote, unauthenticated attacker could exploit this to take control of the system.
- Solution:** Secure the VNC service with a strong password.
- Output:** Nessus logged in using a password of "password". To see debug logs, please visit individual host.
- Hosts:** A table showing the host details: Port 5900 /tcp /vnc, Hosts 10.0.2.3.
- Plugin Details:** Severity: Critical, ID: 61708, Version: \$Revision: 1.2 \$, Type: remote, Family: Gain a shell remotely, Published: August 29, 2012, Modified: September 24, 2015.
- Risk Information:** Risk Factor: Critical, CVSS v2.0 Base Score: 10.0, CVSS v2.0 Vector: CVSS2#AV:N/AC:L/AU:N/C:C/I:C/A:C.
- Vulnerability Information:** Default Account: true, Exploited by Nessus: true.

The bottom of the image shows a Windows taskbar with the date 09/08/2026 and time 16:35.

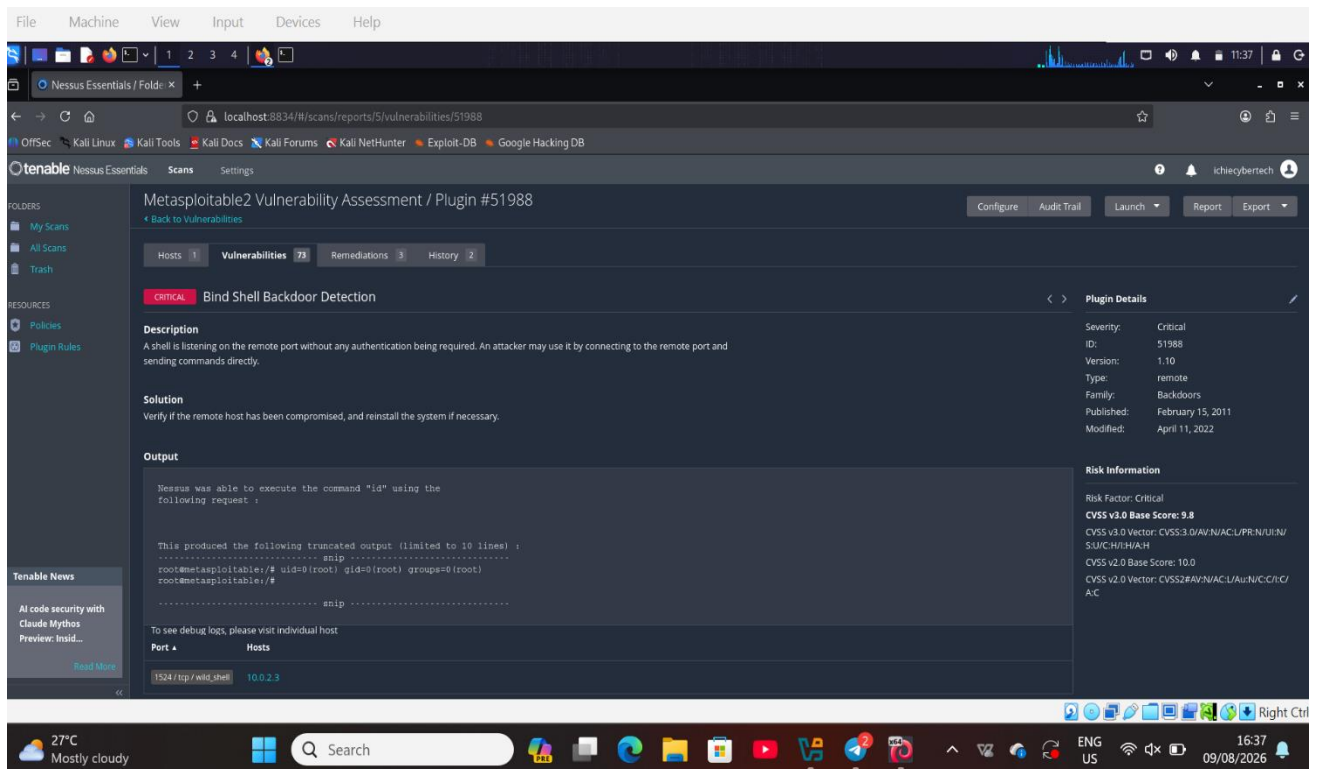
Nessus Evidence of VNC Server 'password' Password

3.3 Bind Shell Backdoor Detection

- ❖ Affected Service: wild_shell – 1524/TCP
- ❖ Severity: Critical
- ❖ CVSS Score: 9.8

Nessus detected a bind shell listening on TCP port 1524. A bind shell exposes a command-line interface over the network and can provide an attacker with direct remote access to the affected system if the service is accessible.

Potential Impact: Unauthorized remote command execution, system compromise, and potential use of the compromised host for further attacks.



Nessus evidence for Bind Shell Backdoor

3.4 SSL Version 2 and 3 Protocol Detection

- ❖ Affected Service:
 - PostgreSQL – 5432/TCP
 - SMTP – 25/TCP
- ❖ Severity: Critical
- ❖ CVSS Score: 9.8

Nessus identified support for the obsolete SSL Version 2 and SSL Version 3 protocols on the affected services. These protocols contain known cryptographic weaknesses and are no longer considered suitable for secure communications. Their continued availability increases the risk of interception and other protocol-based attacks.

Potential Impact: Interception of network communications, downgrade attacks, and potential exposure of sensitive information transmitted through the affected services.

The screenshot displays the Nessus Essentials web interface in a browser window. The main content area shows a vulnerability report titled "SSL Version 2 and 3 Protocol Detection" with a "CRITICAL" severity. The description explains that the remote service accepts connections encrypted using SSL 2.0 and/or SSL 3.0, which are affected by several cryptographic flaws. It lists two main issues: an insecure padding scheme with CBC ciphers and insecure session renegotiation and resumption schemes. The report also mentions that an attacker can exploit these flaws for man-in-the-middle attacks or to decrypt communications. A "Solution" section advises consulting the application's documentation to disable SSL 2.0 and 3.0, and using TLS 1.2 (with approved cipher suites) or higher instead. On the right, the "Plugin Details" section provides technical information: Severity: Critical, ID: 20007, Version: 1.35, Type: remote, Family: Service detection, Published: October 12, 2005, Modified: April 13, 2026. The "Risk Information" section shows a Risk Factor of Critical, a CVSS v3.0 Base Score of 9.8, and a CVSS v2.0 Base Score of 10.0. The "Vulnerability Information" section indicates it is in the news: true. The left sidebar shows the "Scans" tab selected, and the bottom of the browser window shows the Windows taskbar with the date 09/08/2026 and time 16:40.

https://tools.ietf.org/html/rfc7368

Output

- SSLv2 is enabled and the server supports at least one cipher.

Low Strength Ciphers (<= 64-bit key)

Name	Code	KEX	Auth	Encryption	MAC	
EXP-RC2-CBC-MD5		RSA	RSA	RC2-CBC(40)	MD5	export
EXP-RC4-MD5		RSA	RSA	RC4(40)	MD5	export

[More...](#)

To see debug logs, please visit individual host

Port	Hosts
25 /tcp/ smtp	10.0.2.3

- SSLv3 is enabled and the server supports at least one cipher.

Explanation: TLS 1.0 and SSL 3.0 cipher suites may be used with SSLv3

Medium Strength Ciphers (> 64-bit and < 112-bit key, or 3DES)

Name	Code	KEX	Auth	Encryption	MAC	
EXP-RSA-RSA-MD5		RSA	RSA	EXP-RSA-RSA	MD5	

[More...](#)

To see debug logs, please visit individual host

Port	Hosts
5432 /tcp/ postgresql	10.0.2.3

27°C Mostly cloudy

Search

ENG US 16:41 09/08/2026

Nessus evidence for SSL Version 2 and 3 Protocol Detection on PostgreSQL and SMTP services

3.5 rsh Service Detection

- Affected Service: rsh – 514/TCP
- Severity: High
- CVSS: 7.5

Nessus identified the Remote Shell (rsh) service running on TCP port 514. The rsh protocol uses insecure authentication and transmits communication without adequate encryption, making it unsuitable for secure remote administration.

Potential Impact: Credential interception, unauthorized remote access, and possible compromise of the affected system.

The screenshot displays the Nessus Essentials web interface. The main content area shows the 'Metasploitable2 Vulnerability Assessment / Plugin #10245' report. The 'Vulnerabilities' tab is active, showing a single entry for 'rsh Service Detection' with a 'HIGH' severity rating. The report includes a description of the rsh service, a solution to disable it, and an output section indicating no output was recorded. On the right, the 'Plugin Details' sidebar provides metadata such as Severity (High), ID (10245), Version (1.38), Type (remote), Family (Service detection), Published date (August 22, 1999), and Modified date (April 11, 2022). Below this, the 'Risk Information' section shows a Risk Factor of High, a CVSS v2.0 Base Score of 7.5, and the CVSS v2.0 Vector. The 'Vulnerability Information' section notes that exploits are available. At the bottom, the 'Exploitable With' section is visible. The interface also includes a left sidebar with navigation options like 'My Scans', 'AB Scans', and 'Trash', and a top navigation bar with 'Configure', 'Audit Trail', 'Launch', 'Report', and 'Export' buttons. The bottom of the image shows a Windows taskbar with the date 09/08/2026 and time 16:44.

Nessus evidence for rsh Service Detection

3.6 Samba Badlock Vulnerability

- Affected Service: CIFS/SMB – 445/TCP
- Severity: Medium
- CVSS Score: 7.5

Nessus identified the Samba service on TCP port 445 as affected by the Badlock vulnerability. The vulnerability is associated with weaknesses in Samba's handling of certain security mechanisms and may allow an attacker to weaken security protections or perform unauthorized actions, depending on the affected version and configuration.

Potential Impact: Unauthorized access to SMB resources, manipulation of network resources, or privilege-related attacks against the affected system.

The screenshot displays the Nessus Essentials web interface. The main content area shows the details for the 'Samba Badlock Vulnerability' (ID: 90509), which is rated as 'MEDIUM' severity. The description states that the vulnerability affects Samba versions 4.2.11 through 4.4.2, allowing an attacker to force a downgrade of the authentication level, potentially leading to unauthorized access or service disruption. The solution is to upgrade to Samba version 4.2.11 / 4.3.8 / 4.4.2 or later. The 'Output' section shows a message: 'Nessus detected that the Samba Badlock patch has not been applied.' Below this, a table lists the affected hosts and ports:

Port	Hosts
445 / tcp / cifs	10.0.2.3

The right sidebar provides 'Plugin Details' including severity, version, type, family, published date, and modified date. It also includes 'Risk Information' with a risk factor of Medium and a CVSS v2.0 Base Score of 7.5. The 'Vulnerability Information' section at the bottom shows the CPE as 'cpe:/a:samba:samba' and indicates that an exploit is not available.

Nessus evidence for Samba Badlock Vulnerability

3.7 Unencrypted Telnet Server

- Affected Service: Telnet – 23/TCP
- Severity: Medium
- CVSS Score: 6.5

Nessus identified an unencrypted Telnet service running on TCP port 23. Telnet does not provide adequate encryption for authentication or session traffic, meaning information transmitted through the service may be exposed to network interception.

Potential Impact: Exposure of usernames, passwords, and session data, potentially leading to credential theft and unauthorized access to the affected system.

The screenshot displays the Nessus Essentials interface within a virtual machine. The main window shows a vulnerability report for 'Unencrypted Telnet Server' with a 'MEDIUM' severity. The report includes a description, a solution, and an output section showing a Telnet banner. The output section contains the following text:

```
Nessus collected the following banner from the remote Telnet server :
..... snip .....
m3x7g3p01k3b1k3
8022W...
```

The right sidebar provides plugin details, including severity (Medium), ID (42263), version (1.15), type (remote), family (Misc.), published date (October 27, 2009), and modified date (January 16, 2024). The risk information section shows a risk factor of Medium and a CVSS v3.0 base score of 6.5. The bottom of the screen shows a Windows taskbar with the date 09/08/2026 and time 16:48.

Nessus evidence for Unencrypted Telnet Server

4. Risk Assessment

The risk assessment was based on the severity ratings identified by Nessus and the potential impact of successful exploitation. The assessment considers the affected service, potential attacker objectives, and the possible consequences to the target system.

NO. VULN	Vulnerability	Severity	CVSS	Potential Impact	Risk Level	Recommended Priority
VULN-01	UnrealIRCd Backdoor Detection	Critical	10.0	Remote command execution and potential system compromise	Critical	Immediate
VULN-02	VNC Server 'password' Password	Critical	10.0	Unauthorized remote graphical access and possible system compromise	Critical	Immediate
VULN-03	Bind Shell Backdoor Detection	Critical	9.8	Unauthorized remote shell access and command execution	Critical	Immediate
VULN-04	SSL Version 2 and 3 Protocol Detection	Critical	9.8	Possible interception of communications and cryptographic attacks	Critical	Immediate
VULN-05	rsh Service Detection	High	7.5	Credentials exposure and unauthorized remote access	High	High
VULN-06	Samba Badlock Vulnerability	Medium	7.5	Potential unauthorized access or privilege-related attacks	Medium	Planned
VULN-07	Unencrypted Telnet Server	Medium	6.5	Credentials and session-data interception	Medium	Planned

4.1 Risk Prioritization

The assessment results indicate that the identified vulnerabilities require different levels of remediation priority. Critical findings should receive immediate attention because successful exploitation could result in unauthorized access, remote command execution, or significant compromise of the target system.

The High severity rsh finding should also be addressed promptly because the service uses insecure remote-access mechanisms and may expose authentication information.

The Medium severity Samba Badlock and Unencrypted Telnet findings should be addressed through planned remediation. Although their severity is lower than the Critical findings, they still introduce weaknesses that could be exploited to gain unauthorized access or intercept sensitive information.

Overall Risk Assessment

The overall security posture of the assessed Metasploitable 2 system is considered highly exposed due to the presence of multiple Critical and High severity vulnerabilities. The system should not be used in a production environment without appropriate remediation. Priority

should be given to removing backdoors, eliminating weak credentials, disabling insecure protocols, applying security updates, and restricting unnecessary network services.

5. Recommended Controls

NO. VULN	Vulnerability	Recommended Control	How the Control Reduces Risk
VULN-01	UnrealIRCd Backdoor Detection	Remove the vulnerable UnrealIRCd version and upgrade to a supported, patched version. Disable the IRC service if it is not required.	Removes the known backdoor and prevents unauthorized remote command execution through the IRC service.
VULN-02	VNC Server 'password' Password	Replace the weak password with a strong, unique password. Restrict VNC access using firewall rules or VPN and disable VNC when unnecessary	Prevents unauthorized remote desktop access and reduces the likelihood of credential-based compromise
VULN-03	Bind Shell Backdoor Detection	Remove the unauthorized bind shell and investigate its source. Block unnecessary access to TCP port 1524	Eliminate the exposed remote shell and prevents attackers from obtaining unauthorized command-line access
VULN-04	SSL Version 2 and 3 Protocol Detection	Disable SSLv2 and SSLv3 and configure PostgreSQL and SMTP services to use supported TLS versions and secure cryptographic settings	Prevents attackers from exploiting obsolete cryptographic protocols to intercept or weaken protected communication
VULN-05	rsh Service Detection	Disable and remove rsh. Replace it with SSH using strong authentication and appropriate access restrictions	Eliminates insecure remote administration and protects credentials and session traffic from interception
VULN-06	Samba Badlock Vulnerability	Upgrade Samba to a supported patched version and restrict SMB/CIFS access to authorized systems and networks	Remove the known vulnerability and limits unauthorized access to SMB resources
VULN-07	Unencrypted Telnet Server	Disable Telnet and replace it with SSH or another secure remote-administration protocol	Protects credentials and session information from network interception

5.1 Control Implementation Summary

The recommended controls are designed to reduce the likelihood and impact of exploitation by removing vulnerable services, strengthening authentication, applying security updates, replacing insecure protocols, and restricting unnecessary network exposure. Implementation should begin with the Critical findings, followed by the High and Medium severity findings.

These controls should be supported by regular vulnerability scanning, patch management, secure configuration reviews, access control, and continuous monitoring. Together, these measures provide a layered approach to reducing the security risks identified during the assessment.

6. Recommended Policies

6.1 Patch and Vulnerability Management Policy

TechSecure Systems should maintain a formal vulnerability and patch management process. Systems and applications should be regularly scanned for vulnerabilities and identified security updates should be assessed and applied according to their severity and business impact. Critical vulnerabilities should receive immediate remediation priority.

6.2 Secure Remote Access Policy

Remote administration should only be performed through secure protocols such as SSH. Insecure services such as Telnet and rsh should be disabled and removed. Remote-access services should be restricted to authorized users and trusted network locations.

6.3 Password and Authentication Policy

Strong, unique passwords should be enforced for all accounts and network services. Default and weak credentials must be changed before systems are placed into operation. Where supported, multi-factor authentication should be implemented for administrative and remote-access accounts.

6.4 Network Services and Port Management Policy

Only network services required for legitimate business or operational purposes should be enabled. Unnecessary services and exposed ports should be disabled or restricted through firewall and access-control rules. Periodic reviews should be conducted to identify unauthorized or unnecessary network services.

6.5 Secure Configuration and Encryption Policy

Systems and network services should be configured according to secure baseline standards. Deprecated protocols and weak cryptographic configurations, including SSLv2 and SSLv3, should be disabled. Supported TLS versions and approved cryptographic algorithms should be used for protected communications.

6.6 Security Monitoring and Vulnerability Assessment Policy

Regular vulnerability assessments should be performed to identify newly introduced or previously unidentified security weaknesses. Security findings should be documented, prioritized, assigned to responsible personnel, and tracked until remediation is verified. Security logs and alerts should also be monitored to identify suspicious activity.

7. Conclusion

The vulnerability assessment of the Metasploitable 2 system identified multiple security weaknesses across network services, including backdoors, weak authentication, insecure remote-access protocols, outdated cryptographic protocols, and vulnerable SMB services. The assessment demonstrated that several exposed services could provide attackers with opportunities for unauthorized access, credential interception, or remote command execution. The recommended controls and security policies provide a structured approach for reducing these risks through service hardening, patch management, strong authentication, secure remote access, network segmentation, encryption, and continuous vulnerability monitoring. Critical findings should receive immediate remediation, followed by the High and Medium severity findings.

Overall, the assessment demonstrates the importance of regular vulnerability scanning and secure configuration management in maintaining a resilient system. Applying the recommended controls and continuously monitoring the environment will significantly reduce the attack surface and improve the overall security posture of the assessed system.